APPLICATION SECURITY REVIEW

Acme Inventory API

Version 3.2.1 | Warehouse stock service

Approved

No blocking findings. Three low-priority observations are tracked in the backlog.

Review ticket	ASR-2026-033
Application tier	Tier 3 (standard)
Data classification	Internal (stock levels, no personal data)
Product owner	Marcus Oyelaran (Warehouse Operations)
Technical lead	Sofia Alvarez
Hosting	AWS eu-west-1 (ECS, RDS PostgreSQL, S3)
Technology	Python 3.12, PostgreSQL, Docker
Review window	Requested 2026-08-18; testing 2026-08-25 to 2026-08-28; report issued 2026-09-01
Reviewer	AppSec Review Team (demo)
Method	Threat modelling, automated pipeline (secrets, SAST, SCA, IaC, container, DAST), manual code review and authenticated testing; OWASP ASVS 4.0.3 and OWASP Top 10 (2021).

This is a demonstration document. The application, company, people and findings are fictional; the code excerpts and pipeline results are real output from the demo apps in this repository.

1. Executive summary

The Inventory API exposes stock levels to warehouse scanners and the ordering system. It holds no personal data and is classed Tier 3 (standard) with Internal data.

The review found **3 findings, all Low or Informational**. The service follows the secure-by-default patterns we want to see elsewhere: parameterised queries, constant-time credential comparison, an export allow-list, a full set of security headers, a non-root container with a health check, and encrypted, non-public infrastructure.

The pipeline gate passed with zero findings in every stage, and the review confirmed the clean result. This application is presented as the reference for what a passing review looks like.

Critical	High	Medium	Low	Info
0	0	0	1	2

Findings by severity (CVSS v3.1 base score)

Top risk drivers	Single shared API key; No throttling on authentication failures
Pipeline gate	PASS (expected: PASS)
Decision	**Approved**. No blocking findings. Three low-priority observations are tracked in the backlog.
Re-test	No re-test required.

Conditions of approval

- None blocking. Keep the pipeline gate as a required check.

2. Scope and approach

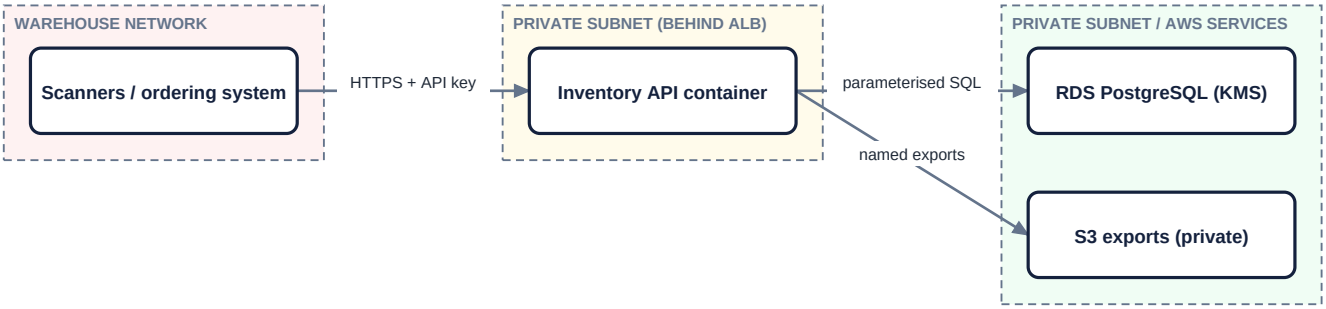
In scope

- Application source (app.py), 74 lines
- Dependency manifest, container build, Terraform
- Dynamic testing including authentication bypass and injection attempts

Out of scope

- Ordering-system client (owned by Supply Chain Apps)
- Warehouse scanner firmware

3. Architecture and trust boundaries



Clients call the API over HTTPS with an API key header. The key is compared in constant time against a stored hash. Queries use placeholders and exports are selected by name from an allow-list.

Good practices observed

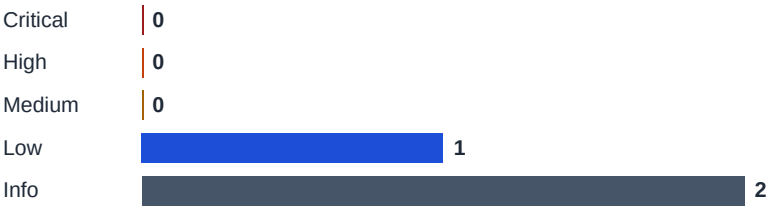
- Parameterised SQL and a query length limit.
- Constant-time comparison of a hashed API key; key loaded from the environment.
- Export names resolved through an allow-list (no path handling).
- Five security headers on every response including errors.
- PBKDF2-HMAC-SHA256 with 600,000 iterations and random salt where passwords are needed.
- Non-root container with HEALTHCHECK and pinned base image.
- Dependencies at current versions with no advisories in the bundled data.
- S3 public access block, encrypted private database.

4. Threat model (STRIDE)

Threats were enumerated per trust boundary. 'Assessment' describes the control state found during the review.

Category	Threat	Existing control	Assessment	Findings
Spoofing	API key required on every route except /health	Constant-time key check	**Mitigated**	INV-02
Tampering	Read-only API; parameterised SQL	Placeholders, allow-list	**Mitigated**	-
Repudiation	Request logs carry client address and route	ALB + app logs	**Mitigated**	INV-02
Information disclosure	Generic errors; no personal data in scope	Headers, no-store	**Mitigated**	-
Denial of service	Query length cap; ALB limits; no per-key throttle	Partial controls	**Partial**	INV-01
Elevation of privilege	Single privilege level, read-only	n/a	**Mitigated**	-

5. Findings summary



ID	Finding	Severity	CVSS	Priority	Source	Due
INV-01	No throttling on failed API-key attempts	**Low**	3.7	P3	Manual review	Backlog
INV-02	One shared API key for all clients	**Info**	n/a	P3	Manual review	Backlog
INV-03	Publish the SBOM and monitor it continuously	**Info**	n/a	P3	Manual review	Backlog

Priority reflects business urgency and can exceed what CVSS alone implies (P0 fix now, P1 before release/go-live, P2 within 30 days, P3 backlog).

6. Detailed findings

INV-01 No throttling on failed API-key attempts	LOW
CVSS	3.7 (CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A:N)
Classification	CWE-307 | A07:2021 Identification and Authentication Failures
Priority / owner / due	P3 | Sofia Alvarez | Backlog
Detected by	Manual review
Description	Failed key checks are not rate limited. A 128-bit random key makes guessing infeasible, so exposure is limited to noise and log volume.
Impact	Minimal; brute force is not practical against the current key length.
Recommendation	Apply a WAF or ALB rate rule on 401 responses and alert on spikes.

Evidence: apps/inventory-api/app.py line 49

```
48 |
49 |     def authorised(self):
50 |         supplied = hashlib.sha256(self.headers.get("X-Api-Key", "").encode()).hexdigest()
```

INV-02 One shared API key for all clients	INFO
CVSS	Not scored (informational)
Classification	CWE-1390 | A04:2021 Insecure Design
Priority / owner / due	P3 | Sofia Alvarez | Backlog
Detected by	Manual review
Description	Every consumer shares one key, so a leak cannot be traced to a client and rotation affects all consumers at once.
Impact	Operational risk only; no vulnerability today.
Recommendation	Issue per-client keys (or OAuth2 client credentials) and rotate on a schedule.

Evidence: apps/inventory-api/app.py line 14

```
13 |
14 | API_KEY_HASH = hashlib.sha256(os.environ.get("INVENTORY_API_KEY", secrets.token_hex(16)).encode(
15 | EXPORTS = {"stock": "stock.csv", "low-stock": "low-stock.csv"}
```

INV-03 Publish the SBOM and monitor it continuously	INFO
CVSS	Not scored (informational)
Classification	CWE-1104 | A06:2021 Vulnerable and Outdated Components
Priority / owner / due	P3 | Sofia Alvarez | Backlog
Detected by	Manual review
Description	The pipeline generates a CycloneDX SBOM per build. It is not yet stored or monitored for newly published advisories after release.
Impact	A new advisory against a shipped version would not trigger an alert.
Recommendation	Archive the SBOM with each release and feed it to a continuous vulnerability monitor.

Evidence: apps/inventory-api/requirements.txt line 1

```
1 | requests==2.32.4
2 | PyYAML==6.0.2
```

7. OWASP ASVS 4.0.3 coverage

Each chapter was assessed at ASVS level 2 for the controls relevant to this application.

Chapter	Result	Notes
V1 Architecture	**Pass**	Documented and reviewed.
V2 Authentication	**Partial**	Strong key; shared and unthrottled.

Chapter	Result	Notes
V3 Session Management	**N/A**	Stateless API.
V4 Access Control	**Pass**	Deny by default.
V5 Validation and Encoding	**Pass**	Placeholders, length cap, allow-list.
V6 Stored Cryptography	**Pass**	PBKDF2 600k, random salt.
V7 Error Handling and Logging	**Pass**	Generic errors, central logs.
V8 Data Protection	**Pass**	Internal data only; no-store.
V9 Communications	**Pass**	TLS 1.2+.
V10 Malicious Code	**Pass**	No secrets or dynamic evaluation.
V11 Business Logic	**Pass**	Read-only.
V12 Files and Resources	**Pass**	Allow-listed exports.
V13 API and Web Service	**Pass**	Consistent auth and headers.
V14 Configuration	**Pass**	Pinned image, current dependencies.

8. Automated pipeline evidence

The demo pipeline ran against this application (run 20261006-173842, commit 9a4fe57). Policy: Acme AppSec release gate (demo).

Stage	Result	Findings	What it checks
Inventory	**PASS**	0	Enumerate files, languages and manifests
Secret scan	**PASS**	0	Regex rules for keys, tokens and credentials (gitleaks-style)
SAST	**PASS**	0	AST rules for injection, crypto and misconfiguration (Semgrep/CodeQL-style)
Dependency scan	**PASS**	0	Pinned packages vs. advisory data (pip-audit/Dependabot-style)
IaC scan	**PASS**	0	Terraform misconfiguration (Checkov/tfsec-style)
Container scan	**PASS**	0	Dockerfile hygiene (Hadolint/Trivy-style)
SBOM	**PASS**	0	CycloneDX 1.5 bill of materials (Syft-style)
DAST	**PASS**	0	Starts the app and probes it over HTTP (ZAP-style)
Release gate	**PASS**	0	Applies policy.json and dated waivers

Gate: PASS. No blocking findings.

9. Remediation roadmap

When	Action
Backlog	Per-client API keys (INV-02).
Backlog	Edge rate limit on 401 responses (INV-01).
Backlog	Archive and monitor the SBOM (INV-03).
Annual	Repeat review at the next major version or after 12 months.

10. Sign-off

Role	Name	Decision / acknowledgement	Date
AppSec reviewer	AppSec Review Team (demo)	**Approved**	2026-09-01
Product owner	Marcus Oyelaran	Acknowledged findings and roadmap	2026-09-01

Role	Name	Decision / acknowledgement	Date
Technical lead	Sofia Alvarez	Accepts remediation dates	2026-09-01
Risk acceptance	None recorded	No residual risk was formally accepted	-

Appendix: rating scales

CVSS v3.1 base score	Severity	Priority	Meaning
9.0 - 10.0	**Critical**	P0	Fix immediately; blocks release.
7.0 - 8.9	**High**	P0 / P1	Fix before release or go-live.
4.0 - 6.9	**Medium**	P1 / P2	Fix within 30 days (earlier when data is sensitive).
0.1 - 3.9	**Low**	P3	Backlog.
None	**Info**	P3	Observation or hardening advice.